

CISSP Printable Practice Exam 15 - Domain 7 - Security Operations

Practice Exam 02 - Domain 7

Choose the best answer for each question. For multi-select items, select all required answers.

Question 1 (CISSP2-117)

Scenario: A university security manager receives an allegation that an employee used institutional systems to operate an unauthorized outside business. No immediate threat to systems exists, and the allegation has not yet been substantiated.

Before collecting employee data, which step is MOST important?

- A. Search every device used by the employee, including personally owned devices
- B. Confirm investigative authority and scope with human resources and legal counsel
- C. Announce the allegation to the employee's department and request witnesses
- D. Disable the employee's access permanently before preserving relevant records

Question 2 (CISSP2-118)

Scenario: A construction firm receives notice of a civil lawsuit involving a terminated project. Relevant email, access logs, and collaboration records are subject to routine deletion schedules that will begin removing data within days.

Which action is MOST appropriate?

- A. Export only records that appear favorable to the firm's position
- B. Allow normal deletion to continue until a court specifically requests each record
- C. Have individual custodians decide which records should be retained
- D. Implement a counsel-directed legal hold that suspends deletion for relevant information

Question 3 (CISSP2-119)

Scenario: A transportation company sends many security events to its SIEM, but analysts receive thousands of repetitive alerts and have missed several meaningful sequences spread across different systems.

Which THREE actions would MOST improve detection quality? Select 3 of the 5 options below.

- A. Normalize important fields and correlate events across relevant sources
- B. Suppress every alert generated more than once in a day
- C. Tune rules using documented use cases, risk, and analyst feedback
- D. Test detection logic against representative benign and malicious activity
- E. Retain only events that have already triggered confirmed incidents

Question 4 (CISSP2-120)

Scenario: A software company automatically creates short-lived compute instances for data-processing jobs. Reviewers find that teams use different base images and sometimes embed administrative secrets in deployment templates.

Which control would BEST improve secure provisioning?

- A. Let each project maintain an undocumented image to preserve flexibility
- B. Store long-lived administrative secrets in every approved image
- C. Deploy approved hardened images and retrieve short-lived secrets from a controlled service
- D. Perform a manual annual inventory instead of validating each deployment

Question 5 (CISSP2-121)

Scenario: At a charitable foundation, one accounts-payable specialist can create a new vendor, change its banking details, and release payment without another person's review.

Which change would BEST reduce the risk of fraud?

- A. Require independent approval for vendor changes and payment release
- B. Give the specialist a second account for high-value payments
- C. Increase the specialist's transaction limit to reduce processing delays
- D. Review only payments that recipients later dispute

Question 6 (CISSP2-122)

Scenario: A gaming company has allowed one operations employee to reconcile the same sensitive transaction queue for several years. Management is concerned that errors or manipulation could remain hidden because no one else performs the process.

Which practice would MOST directly address this concern?

- A. Increase the employee's system privileges so reconciliation is faster
- B. Remove all logs after each reconciliation cycle
- C. Let the employee select a trusted substitute only when convenient
- D. Implement planned job rotation with independently assigned personnel

Question 7 (CISSP2-123)

Scenario: A medical research institute transports removable backup media to an off-site vault each week. The media contains sensitive study records and passes through a contracted courier before reaching controlled storage.

Which THREE controls are MOST appropriate for this process? Select 3 of the 5 options below.

- A. Write the media decryption key on the outside of the transport case
- B. Encrypt the media with keys managed separately from the shipment
- C. Use tamper-evident packaging and documented custody transfers
- D. Allow the courier to store delayed shipments at any convenient location
- E. Reconcile media identifiers and receipt records at the destination

Question 8 (CISSP2-124)

Scenario: A travel services provider detects an access token being used from an unexpected location to download internal files. The legitimate user confirms that the activity is not theirs, and centralized audit records are available.

What should the incident responder do FIRST?

- A. Wait for the token to expire naturally so the actor's behavior can be observed
- B. Revoke the token, contain related sessions, and preserve relevant audit evidence
- C. Delete the user's account and all files accessed with the token
- D. Restore the affected service from backup before limiting access

Question 9 (CISSP2-125)

Scenario: A water treatment facility needs better visibility into suspicious traffic on a legacy control network. Some controllers may fail if inline devices delay, block, or modify their communications.

Which initial approach BEST addresses the requirement?

- A. Place an untested prevention device inline and enable automatic blocking
- B. Install host agents on every controller without compatibility testing
- C. Use passive network intrusion detection from monitored traffic copies
- D. Disable network monitoring to preserve controller availability

Question 10 (CISSP2-126)

Scenario: A museum operates public information kiosks that run a small, stable set of approved applications. Attackers have repeatedly tried to execute downloaded tools after escaping the kiosk interface.

Which preventive measure would be MOST effective?

- A. Allow execution only for explicitly approved applications and supporting components
- B. Maintain a list containing only the malicious files already observed
- C. Permit all signed applications regardless of business need
- D. Rely solely on weekly review of kiosk event logs

Question 11 (CISSP2-127)

Scenario: A retailer finds the same high-severity software flaw on an isolated training server and on an internet-facing order system that processes sensitive customer data. The order system has no effective compensating control, while the training server is scheduled for retirement.

How should the vulnerability manager prioritize remediation?

- A. Patch the training server first because it is easier to schedule
- B. Assign identical deadlines because the technical severity is the same
- C. Defer both systems until the next annual maintenance cycle
- D. Prioritize the order system based on exposure, business impact, and lack of mitigation

Question 12 (CISSP2-128)

Scenario: Continuous monitoring detects a new firewall rule that permits broad inbound access to a production database segment. No approved change record exists, but immediately deleting the rule could interrupt a business process whose owner has not yet been identified.

What is the BEST next action?

- A. Leave the rule indefinitely because removing it might affect operations
- B. Invoke the unauthorized-change procedure, assess exposure and dependency, then contain or roll back safely
- C. Create a retroactive approval record without investigating who added the rule
- D. Disable firewall logging so additional unrecorded changes do not generate alerts

Question 13 (CISSP2-129)

Scenario: A reservation system has a recovery point objective of 15 minutes. Its current nightly backup process could require the business to recreate nearly a full day of transactions after a failure.

Which improvement MOST directly supports the stated objective?

- A. Increase the recovery time objective to twenty-four hours
- B. Move the nightly copy to a storage device with greater capacity
- C. Capture transaction changes at intervals that limit data loss to 15 minutes or less
- D. Perform an annual walkthrough of the recovery contact list

Question 14 (CISSP2-130)

Scenario: An emergency communications center relies on one network gateway. A gateway hardware failure currently disconnects dispatch workstations until technicians install a replacement.

Which solution would BEST improve fault tolerance?

- A. Deploy redundant gateways with automatic state-aware failover and test the failover process
- B. Keep a configuration manual in a locked cabinet near the gateway
- C. Purchase a replacement gateway that remains unopened at another facility
- D. Extend the retention period for gateway traffic logs

Question 15 (CISSP2-131)

Scenario: A securities clearing organization operates two active processing sites in the same metropolitan area. Both use different buildings but depend on the same electrical substation and telecommunications exchange.

Which change would provide the GREATEST resilience against a regional disruption?

- A. Add more servers to each existing site without changing external dependencies
- B. Assign separate facility names to distinguish the two locations in documentation
- C. Move both sites onto different floors of the newer building
- D. Establish processing capacity in a geographically separated area with independent utility paths

Question 16 (CISSP2-132)

Scenario: An insurance company wants cross-functional teams to respond to a realistic data-center outage scenario, make recovery decisions as conditions evolve, and identify coordination gaps without switching production services.

Which THREE elements belong in the proposed exercise? Select 3 of the 5 options below.

- A. A complete unannounced shutdown of the production data center
- B. A defined scenario with timed operational developments
- C. Participation by business, technology, facilities, and communications roles
- D. A requirement to make recovered systems serve live customer traffic
- E. Documented observations, decisions, gaps, and assigned corrective actions

Question 17 (CISSP2-133)

Scenario: During a warehouse evacuation drill, supervisors cannot determine whether contractors working in remote loading areas reached the assembly point. Badge records show entry but do not reliably reflect current location or exit.

Which improvement should receive the HIGHEST priority?

- A. Require contractors to recover company equipment before leaving the building
- B. Implement inclusive muster, accountability, and escalation procedures for employees and contractors
- C. Delay evacuation until supervisors reconcile all badge records indoors
- D. Limit future drills to office employees so results are easier to measure

Question 18 (CISSP2-134)

Scenario: A data center permits maintenance vendors to enter equipment rooms after signing a paper log. A recent review found that visitors sometimes separate from their escorts and remain in restricted areas after their scheduled work ends.

What is the BEST corrective measure?

- A. Allow vendors to borrow employee badges so doors do not delay maintenance
- B. Replace the paper log with a camera but permit unescorted movement
- C. Issue time-limited visitor credentials, enforce escort rules, and reconcile exit

D. Give recurring vendors permanent access to all equipment rooms

Question 19 (CISSP2-135)

Scenario: Executives from a renewable energy company will visit a region where device searches, theft, and targeted social engineering are credible concerns. They need limited access to current business documents during the trip.

Which preparation is MOST appropriate?

- A. Provide a travel briefing, minimally provisioned devices, limited data access, and a check-in and incident process
- B. Let travelers use their normal devices with complete archives for convenience
- C. Require travelers to conceal incidents until they return to avoid disrupting the trip
- D. Publish the itinerary and contact details broadly so colleagues can monitor progress

ANSWER KEY AND EXPLANATIONS

Question 1 (CISSP2-117) - Correct: B

An administrative investigation should begin with confirmed authority, scope, and coordination with the functions responsible for employment and legal requirements. Searching personal devices may exceed organizational authority. Broadly announcing an unsubstantiated allegation can compromise privacy and fairness, while permanent access removal before evidence preservation is premature and may impede the inquiry.

Question 2 (CISSP2-118) - Correct: D

A counsel-directed legal hold preserves potentially relevant electronically stored information by suspending normal destruction for the defined matter. Selective preservation can omit discoverable evidence, routine deletion may become spoliation after a preservation duty arises, and decentralized custodian decisions lack consistent scope and oversight.

Question 3 (CISSP2-119) - Correct: A, C, D

Normalization and cross-source correlation reveal related activity, risk-based tuning reduces noise without blindly discarding signals, and representative testing verifies that detection logic works as intended. Suppressing every recurring alert can hide repeated attacks. Keeping only events tied to known incidents eliminates context needed to discover new or evolving activity.

Question 4 (CISSP2-120) - Correct: C

Approved hardened images create a consistent provisioning baseline, and controlled retrieval of short-lived secrets avoids embedding reusable credentials in templates or images. Undocumented images weaken traceability. Long-lived embedded secrets expand exposure, while an annual inventory cannot assure the security of rapidly created instances.

Question 5 (CISSP2-121) - Correct: A

Independent approval separates incompatible duties so one individual cannot establish a payment destination and release funds without oversight. A second account does not create independence. A higher limit increases exposure, and reviewing only disputed transactions is reactive and may miss successful fraud.

Question 6 (CISSP2-122) - Correct: D

Planned job rotation brings independent personnel into the function, increasing the chance that hidden errors or abuse will be identified while also reducing reliance on one employee. Additional privilege increases risk. Deleting logs removes evidence, and a substitute chosen only by the incumbent does not provide consistent independent scrutiny.

Question 7 (CISSP2-123) - Correct: B, C, E

Encryption with separately controlled keys protects confidentiality, tamper-evident packaging and custody records support integrity and accountability, and destination reconciliation confirms that the correct media arrived. Placing a key on the case defeats encryption, while unapproved temporary storage breaks the controlled transport process.

Question 8 (CISSP2-124) - Correct: B

Revoking the exposed credential and containing associated sessions stops active misuse, while preserving audit evidence supports scoping and investigation. Waiting prolongs exposure. Deleting the account and files can destroy evidence and disrupt legitimate work, and restoration does not address an attacker who still holds valid access.

Question 9 (CISSP2-125) - Correct: C

Passive network intrusion detection can improve visibility without sitting inline or altering traffic, making it a prudent initial choice for availability-sensitive legacy systems. Untested inline prevention and host agents may disrupt operations. Disabling monitoring preserves neither visibility nor the ability to detect attacks.

Question 10 (CISSP2-126) - Correct: A

Application allowlisting is well suited to fixed-function kiosks because the legitimate software set is small and stable; unapproved downloaded tools are denied by default. A blocklist addresses only known files. Trusting every signed application exceeds need, and weekly log review is detective rather than preventive.

Question 11 (CISSP2-127) - Correct: D

Technical severity is only one input to remediation priority. The internet-facing order system combines exposure, valuable data, business criticality, and no effective mitigation, so it represents the greater environmental risk. Convenience, identical deadlines, and annual deferral fail to account for those material differences.

Question 12 (CISSP2-128) - Correct: B

The unauthorized-change process should preserve evidence, determine risk and operational dependency, and support timely containment or safe rollback. Leaving broad access in place prolongs exposure. Retroactive approval conceals a control failure, while disabling logging destroys visibility and accountability.

Question 13 (CISSP2-129) - Correct: C

The recovery point objective defines the maximum tolerable amount of recent data loss, so the protection method must capture changes frequently enough to keep that loss within 15 minutes. Storage capacity does not determine data currency. Changing the recovery time objective addresses downtime rather than data loss, and a contact-list walkthrough does not improve the restore point.

Question 14 (CISSP2-130) - Correct: A

Redundant gateways with automatic, tested failover allow service to continue when one component fails. Documentation and an unopened spare may speed manual recovery but still permit an outage. Longer log retention supports investigation, not continuity of the gateway service.

Question 15 (CISSP2-131) - Correct: D

Geographic separation and independent utility paths reduce the correlated risks that could disable both current sites at once. More servers do not help if shared external services fail. Naming changes have no operational effect, and colocating the sites in one building increases common-mode exposure.

Question 16 (CISSP2-132) - Correct: B, C, E

A simulation uses a realistic scenario and evolving inputs to exercise cross-functional decision-making without disrupting production. Capturing gaps and assigning corrective actions turns observations into improvement. Shutting down production or serving live traffic would introduce the operational risk of more disruptive test types and is not required for this objective.

Question 17 (CISSP2-133) - Correct: B

Emergency procedures must account for everyone on site through defined assembly, reporting, and escalation methods that work for employees and contractors. Equipment recovery and indoor reconciliation can delay evacuation and endanger personnel. Excluding contractors

from drills leaves the identified life-safety gap unresolved.

Question 18 (CISSP2-134) - Correct: C

Time-limited visitor credentials, enforced escorts, and exit reconciliation constrain access to the authorized period and preserve accountability. Borrowed employee badges undermine attribution. Cameras are detective and do not replace access restrictions, while permanent broad access exceeds the vendors' temporary need.

Question 19 (CISSP2-135) - Correct: A

A tailored briefing, minimally provisioned devices, restricted data access, and clear communications and incident procedures reduce both personnel and information risk while supporting the business need. Full archives increase exposure, delayed reporting impedes response, and broad itinerary publication can create additional targeting risk.